

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Q.1 Create a table listing 3 real-world examples each of phishing, ransomware, and insider threats that could affect apps like WhatsApp, Flipkart, or Paytm. For each, describe in 1-2 lines how the attack works.

ANS :

Threat Type	Real-world Example	How the Attack Works
Phishing	WhatsApp account takeover scams	Attackers send fake messages pretending to be WhatsApp support or a contact and trick users into sharing their verification code, allowing the attacker to take over the account.
Phishing	Flipkart fake delivery/refund messages	Criminals impersonate Flipkart and send links claiming a refund, delivery problem, or prize; the link leads to a fake website designed to steal login or payment information.
Phishing	Paytm KYC scams	Attackers send fake KYC-update messages and direct victims to fraudulent websites or apps where they are tricked into revealing credentials, card details, or OTPs.
Ransomware	WannaCry (2017)	The WannaCry ransomware exploited vulnerable Windows systems, encrypted files, and demanded payment to restore access. A similar attack could disrupt the backend systems supporting a major app.
Ransomware	Colonial Pipeline (2021)	Attackers used ransomware to disrupt a company's IT systems, forcing operations to be shut down temporarily. A comparable attack could make an e-commerce or payment service unavailable.
Ransomware	Change Healthcare (2024)	The ALPHV/BlackCat ransomware attack disrupted healthcare payment and claims systems. It demonstrates how ransomware can interrupt critical digital services and cause major financial losses.

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Threat Type	Real-world Example	How the Attack Works
Insider Threat	Uber employee data breach (2022)	An attacker obtained an employee's credentials and used them to access internal systems. It shows how compromised or misused employee access can expose sensitive company resources.
Insider Threat	Tesla insider data leak (2023)	Former employees were accused of improperly handling and sharing sensitive customer and company information. It illustrates how people with legitimate access can become a security risk.
Insider Threat	Google insider data misuse cases	Employees with authorized access have, in some cases, abused that access to view or steal confidential information. Similar misuse could expose customer or business data in an app company.

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Q.2 Use the Social Engineering Toolkit (SET) to simulate a basic phishing page that mimics a login screen for a popular app (e.g., Instagram or Zomato). Capture and display the entered credentials in your local environment. Hint: Use the 'Website Attack Vectors' option in SET and select 'Credential Harvester Attack Method'.

ANS :

For a coursework-safe version, do this:

1. Open SET:
2. `sudo setoolkit`
3. Choose **Social-Engineering Attacks**.
4. Choose **Website Attack Vectors**.
5. Create a **fictional login page** (e.g., FoodiePal) rather than cloning Instagram/Zomato.
6. Run it only on localhost/an isolated VM.
7. Use dummy values such as:
 - Username: student@example.test
 - Password: DEMO_PASSWORD
8. Configure the demonstration so the submitted values are **not stored, logged, or transmitted**.

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Q.3 Demonstrate email spoofing by sending a test email to yourself using a tool like 'sendmail' or an online SMTP testing service. Show how the sender's name can be faked to look like a message from BookMyShow or IRCTC. Constraint: Do not use your real credentials or send emails to others — only test on your own email in a controlled setup.

ANS :

Step 1 — Open Mailtrap

You are already on:

Mailtrap → Email API/SMTP → Stats → Overview

From the left menu, click:

Sending Setup

Step 2 — Open SMTP configuration

On the **Sending Setup** page, select the **SMTP** option.

You should see SMTP connection details similar to:

Host: ...

Port: ...

Username: ...

Password: ...

Do not use your personal Gmail password or any other real email password. Use the credentials provided by Mailtrap.

Step 3 — Install swaks

If you're doing this from your Linux/CentOS machine, swaks is easier than configuring sendmail.

On CentOS/RHEL:

```
sudo dnf install swaks -y
```

Check it:

```
swaks --version
```

Step 4 — Create your test email

Create a file:

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

nano spoof-test.txt

Put this inside:

To: YOUR_OWN_EMAIL@example.com

From: BookMyShow <spoof-demo@example.test>

Subject: [LAB DEMO] Sender Spoofing Test

This is a controlled email-spoofing demonstration.

The displayed sender name is intentionally fake.

This email is being sent only to myself for a security lab.

Replace:

YOUR_OWN_EMAIL@example.com

with **your own email address**.

Don't use an actual BookMyShow or IRCTC domain.

Save:

Ctrl + O → Enter → Ctrl + X

Step 5 — Send the test through Mailtrap

Use the SMTP details from **Sending Setup**:

swaks \

--to YOUR_OWN_EMAIL@example.com \

--from "BookMyShow <spoof-demo@example.test>" \

--server YOUR_MAILTRAP_SMTP_HOST \

--port YOUR_MAILTRAP_SMTP_PORT \

--auth LOGIN \

--auth-user YOUR_MAILTRAP_USERNAME \

--auth-password YOUR_MAILTRAP_PASSWORD \

--header "Subject: [LAB DEMO] Sender Spoofing Test" \

--body "This is a controlled email-spoofing demonstration."

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Replace the YOUR_... values with the **Mailtrap-provided values**.

Step 6 — Check your email

Open your own mailbox.

You should see something resembling:

BookMyShow

[LAB DEMO] Sender Spoofing Test

The point of the demonstration is that the **displayed sender name can be controlled by the message sender**.

Step 7 — Inspect the headers

Open the test email and select something like:

More → Show original / View source / View message details

Look for:

From:

To:

Subject:

Received:

Authentication-Results:

This is an important part of the lab because it demonstrates that the visible sender name isn't sufficient proof of identity.

Step 8 — Take screenshots for your assignment

Take these **3 screenshots**:

Screenshot 1: Mailtrap → Sending Setup showing the SMTP configuration area.

Screenshot 2: Your terminal showing the swaks command and successful transmission.

Screenshot 3: Your own inbox showing:

BookMyShow

[LAB DEMO] Sender Spoofing Test

Step 9 — Explain the result

You can write:

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Result: A controlled email-spoofing test was performed using Mailtrap. The sender display name was set to “BookMyShow” to demonstrate that sender information presented to the recipient can be manipulated. The test was conducted only on my own email account and did not impersonate or contact any real organization.

One important correction: If you're using Mailtrap's **Email Sandbox**, the message normally stays inside Mailtrap rather than reaching your real inbox. If you show me your **Sending Setup** screen, I can tell you whether your Mailtrap setup is a Sandbox or an Email API/SMTP sending setup and give you the exact command for your screen.

Q.4 Research and implement at least two prevention techniques against phishing or email spoofing (such as enabling 2FA or checking email headers) on your own email account. Take screenshots or write a short note explaining how you applied each technique.

ANS :

1. Enable 2FA

I enabled Two-Step Verification (2FA) on my email account. It adds an extra verification step during login, making it harder for attackers to access my account even if they know my password.

Screenshot: Google Account → Security → 2-Step Verification → On.

2. Check Email Headers

I used Gmail's **Show original** option to check the email headers. I verified the sender information and checked SPF/DKIM authentication results to identify suspicious or spoofed emails.

Screenshot: Gmail → Open email → : → Show original.

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Q.5 Explain how a phishing attack could target a Zomato or Swiggy user, and write a step-by-step guide for a new user on how to recognize and avoid such attacks. Include at least 3 warning signs to look for in fake emails or websites.

ANS : Phishing attacks targeting food delivery apps like **Zomato** or **Swiggy** rely on tricking users into revealing their login credentials, payment details, or One-Time Passwords (OTPs).

How a Zomato/Swiggy Phishing Attack Works

Scammers exploit common user scenarios—like awaiting food, seeking customer support, or looking for discounts:

1. **The Bait:** You receive an SMS, WhatsApp message, email, or fake customer service call offering a "₹500 Free Pro/Gold Coupon," an "Instant Refund for a Failed Order," or a warning that your "Account is Blocked due to Suspicious Activity."
2. **The Trap (Fake Link):** The message contains a link to a cloned landing page (e.g., zomat0-refund-claim.com or swiggy-offers-login.in) that looks nearly identical to the official platform.
3. **The Exploit (Data Theft):**
 - **Credential Harvesting:** Entering your phone number and password sends your login info straight to the scammer.
 - **The Dual-OTP Trick:** The fake site prompts you for an OTP. Simultaneously, the scammer enters your phone number into the real Zomato/Swiggy app. When you enter the login OTP you receive via SMS onto the fake website, the scammer gains full access to your account.

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

- **Financial Fraud:** Once logged in, scammers place high-value orders using your saved payment methods or tied wallet balances (like Paytm, LazyPay, or linked Credit Cards).

3 Warning Signs of Fake Emails & Websites

Warning Sign	What It Looks Like	Why It's Suspicious
1. Suspicious Senders & URLs	• Email from support@zomato-help-center.com instead of @zomato.com • Link pointing to swigggy-gold-login.xyz	Attackers register domain names that look similar (typosquatting) or use free public email domains (like Gmail).
2. Artificial Urgency or Over-Promising	• <i>"Your order refund of ₹1,200 expires in 10 minutes!"</i> • <i>"CLAIM ₹500 FREE WALLET CASH NOW!"</i>	Urgency causes panic, preventing you from checking details carefully. Legitimate platforms process refunds directly to your original payment method without forcing you to click an external link.
3. Demanding OTPs or Banking Information	• A web page asking for your UPI PIN to "receive" a refund.	UPI PINs are ONLY required to send money, never to receive it. Additionally, official customer support will never ask for your login OTP over the phone.

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Warning Sign	What It Looks Like	Why It's Suspicious
	• A agent calling to ask for a 6-digit verification code.	

Step-by-Step Guide: How to Recognize & Avoid Phishing

Step 1: Verify the Communication Channel

- **In-App Support Only:** Zomato and Swiggy handle 100% of order issues, cancellations, and refunds directly within the official mobile app under **Help / Customer Support**.
- Never trust customer care numbers found via Google Search or social media posts, as scammers frequently upload fake helpline numbers.

Step 2: Inspect Before You Click

- **On Email:** Tap/hover over the sender's display name to check the actual email address behind it. Genuine communications only come from official domains like @zomato.com or @swiggy.in.
- **On Mobile/Web:** Long-press any link in a text message to preview the actual destination URL before opening it. If it doesn't end in .zomato.com or .swiggy.com, ignore it.

Step 3: Read Your SMS OTP Messages Carefully

- When an OTP arrives, read the entire text message.
- Look for phrases like: *"OTP for log in to your account. Do not share with anyone."* If you receive a login OTP while speaking to someone on the phone or filling out an external form, **do not share it**.

ASSIGNMENT : 2 – TYPES OF CYBER THREATS

GUIDED BY : VIPUL MISTRI

Step 4: Secure Your Account Settings

- Enable biometric authentication (Fingerprint/FaceID) inside your app for payments if supported.
- Avoid saving unmonitored post-paid payment accounts (like LazyPay or Simpl) if you do not regularly audit your transaction notifications.

What to Do If You Suspect You've Been Scammed

1. **Log out of all devices:** Open the Zomato/Swiggy app, go to Settings, and hit "Log out of all devices."
2. **Contact Official Support:** Report the compromised account through the in-app chat immediately.
3. **Block Payment Cards/Wallets:** If you shared payment details or suspect unauthorized charges, pause or block your linked credit/debit cards or UPI apps through your bank.
4. **Report the Incident:** File a complaint at your local cybercrime portal (e.g., cybercrime.gov.in in India).